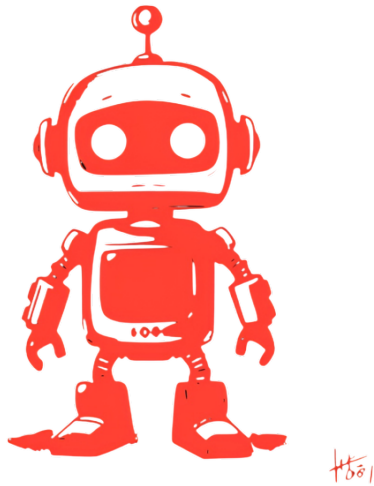




AEGIS



NFR- Requirements

MAPPING QUALIFY REQUIREMENTS TO ARCHITECTURAL DECISIONS

Quality Requirements	Architectural Decision
Performance (NFR 1.1, NFR 1.2):	Use an asynchronous FastAPI backend with stateless request handling, connection pooling, and a horizontally scalable deployment model so multiple candidates can be served concurrently without blocking.
Usability (NFR 2.1): (Error Handling)	Enforce centralised API validation and structured error responses using FastAPI and Pydantic, so invalid input and failed requests return clear, field-level messages without exposing internal stack traces.
Usability (NFR 2.2): (Accessibility)	Build the frontend in Next.js using semantic HTML, keyboard-navigable components, and contrast-compliant styling to support users with different accessibility needs.
Reliability (NFR 4.1, NFR 4.2)	Use Supabase managed PostgreSQL with automated backups and recovery support, combined with a stateless application layer, so the system can be restored after failures without losing confirmed data.
Security (NFR 3.1)	Enforce JWT-based authentication and role-based authorization on every protected endpoint, with additional ownership checks so candidates can only access their assigned assessments and recruiters can access admin functions only.

Maintainability (NFR 5.1, NFR 5.2)	Adopt a three-tier layered architecture that separates presentation, application, and data concerns, with clear module boundaries and API contracts to keep coupling low and allow independent changes.
---	---

TRACEABILITY MATRIX:

ID	Quantified requirement	Tactic in SAS	Test / tool	Target / actual
QR-AC01	100% rejection of unauthenticated requests across all protected endpoints	Global JWT Authentication Middleware via FastAPI dependencies	pytest + TestClient (test_gap_endpoint_rejects_unauthenticated)	100% rejection (HTTP 401) / PASS (12/12 endpoints)
QR-AC02	100% rejection of candidate roles attempting to access admin/recruiter endpoints	Role-Based Access Control (RBAC) route guards	pytest + TestClient (test_gap_endpoint_rejects_wrong_role)	100% rejection (HTTP 403) / PASS (12/12 endpoints)
QR-AC03	100% rejection of recruiter requests targeting resources owned by other recruiters	Resource Ownership Checks (Row-Level Scoping / creator_id validation)	pytest + TestClient (test_gap_endpoint_rejects_authenticated_not_owner)	100% rejection (HTTP 403/404) / XFAIL (Open Gap: Missing ownership validation)